

Taweed - Counsel Scoping Checklist

PDPL / Saudi Regulatory Review - Prepared for KSA Privacy Counsel

Prepared 2026-07-20

Taweed is a Saudi SaaS product that analyzes health-insurance claims data for clinics (a denial-management / revenue-cycle recovery platform) - it is administrative and billing software, not a medical device or a clinical decision-support tool. It is hosted in-Kingdom (Oracle Cloud Riyadh region / AWS Riyadh region) and uses a US-based large-language-model subprocessor (Anthropic) for its AI-assisted features (denial explanations, appeal drafting, document extraction). Below is what we would like to cover in a fixed-scope engagement before any real patient claims data is processed in production.

1. Data flow and Data Processing Agreement (DPA)

- [] Review our actual data flow end-to-end and confirm no personal health data crosses the Saudi border anywhere in the system - including logging, analytics, backups, and transactional email, not just the obvious AI-call path.
- [] Draft our standard Data Processing Agreement (DPA) template to use with clinic customers.

2. Cross-border transfer to our AI subprocessor - SCCs and risk assessment

- [] Confirm the Saudi Standard Contractual Clauses (SCC, Controller-to-Processor form) are the correct safeguard for transferring data to our US-based LLM provider (Anthropic). No Saudi Data & AI Authority (SDAIA) 'adequacy list' of approved destination countries has been published, so an Appropriate Safeguard is the applicable route by elimination.
- [] Produce the mandatory SDAIA cross-border risk assessment for sensitive / health-data transfers (per SDAIA's February 2025 Risk Assessment Guideline, using the self-assessment tool on the National Data Governance Platform, dgp.sdaia.gov.sa). This is understood to be a hard requirement, not optional paperwork, whenever relying on an Appropriate Safeguard for sensitive data.

3. NPHIES portal Terms & Conditions - business-risk read

- [] We operate on Saudi Arabia's national health-claims exchange platform, NPHIES (nphies.sa). Its Terms & Conditions page (nphies.sa/terms-and-conditions) is a binding agreement containing a liability-limitation clause, an indemnity clause running in NPHIES's favor, and a unilateral right to suspend or terminate access without notice. Please review it and advise: is this an acceptable risk to operate under, or does it need a mitigation (for example, contractual language with our clinic customers allocating that risk)?
- [] Specific question 1: the Terms' disclaimer-of-warranties clause states that user communications sent through the portal carry no confidentiality guarantee on NPHIES's part. Does this plausibly extend to actual claims-transaction data submitted through the platform, or is it scoped only to generic portal-support channels such as contact forms and chat? We do not want to assume the

answer either way.

- [] Specific question 2: the Terms' intellectual-property clause bars redistribution or creation of derivative works from portal content without NPHIES's written approval. Separately, the technical specification package we integrate against (the NPHIES Implementation Guide, published by HL7 Saudi Arabia) carries its own copyright notice with no unrestricted open-source grant. Taken together, does this mean we genuinely cannot bundle any NPHIES-derived technical material into our product or CI pipeline without written sign-off from NPHIES / HL7 Saudi Arabia?

4. Breach-notification runbook

- [] Help us draft a breach-response runbook meeting SDAIA's 72-hour breach-notification requirement. There is no materiality threshold and no exemptions, so every breach size is understood to be notifiable. The runbook needs to cover: detection, notifying SDAIA within 72 hours, and notifying affected data subjects 'without undue delay' where harm is possible.

5. Controller vs. processor determination, registration, and DPO

- [] Make the controller-vs-processor determination for our relationship with clinic customers. Our working assumption is that the clinic is the controller and we are the processor - please confirm this rather than let us assume it.
- [] Depending on that answer: does registration on SDAIA's National Data Governance Platform, or appointment of a mandatory Data Protection Officer, attach to us specifically? These duties are generally understood to attach to the controller, but please confirm nothing about our specific setup shifts that.
- [] Whichever party ends up formally responsible for notifying SDAIA of a breach, please confirm that we, as processor, still need to notify the clinic fast enough for the clinic to hit its own 72-hour clock - regardless of how the controller/processor question above resolves.

6. Quick sanity checks

- [] SAMA payment-services perimeter: our revenue model is a base fee plus a percentage of recovered claims value, billed to the clinic as a separate B2B invoice - the insurer pays the clinic directly, and we are never in the payment path and never hold funds. Please confirm this stays outside SAMA's regulated 'payment services' definition; a one-line confirmation is sufficient.
- [] Business-registration path: confirm standard Saudi Commercial Registration (CR) is sufficient, with no MISA investment license needed, given the founder is a Saudi national.
- [] CST Cloud Computing Regulatory Framework applicability: we build our own software application and run it on a third-party cloud provider (Oracle Cloud / AWS) - we do not own or operate any data center or infrastructure ourselves. Does this require registration with the Communications, Space & Technology Commission (CST) as a cloud computing service provider? CST's public registration criteria describe the trigger as a provider that 'directly or effectively controls the data center or critical infrastructure,' but CST's materials also state the framework was 'expanded to expressly cover SaaS,' without a clear carve-out we could find for

a SaaS application built on someone else's infrastructure. We would like a definitive read before going live.

This checklist reflects our own good-faith reading of publicly available regulations and official portals; it is not legal advice and every item above is a question for counsel to confirm, correct, or expand upon.